PUBLIC KEY INFRASTRUCTURE

S03: Quản trị CA, Chính sách CP/CPS & Tự động hóa ACME

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 3 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 17/10/2026 · 13h30–18h30
Standards: IETF RFC 3647, RFC 8555 (ACME), Step-CA

1. Tổng quan & Lộ trình Buổi S03

Lộ Trình Học Phần (Buổi 3/9)

S01: Architecture, Trust & Threat Models	S02: X.509, ASN.1 & Path Validation	**S03: CA Lifecycle & ACME Protocol**
S04: Revocation (CRL/OCSP) & Hardware HSM	S05: TLS 1.3 & mTLS Zero Trust Gateway	S06: Certificate Transparency (CT) Logs & Merkle Tree
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Buổi học chuyển dịch từ cấu trúc tĩnh sang vận hành động: cách thiết kế hệ thống CA cấp doanh nghiệp, chính sách pháp lý CP/CPS và giao thức cấp phát tự động ACME.



S3-1 · Lộ Trình Học Phần (Buổi 3/9)

[2 phút | 13h30–13h32] Giới thiệu chủ đề Buổi 3: Quản trị vòng đời CA và giao thức tự động hóa ACME RFC 8555.

Chuẩn Đầu Ra Buổi Học S03 (Learning Objectives)

Sau buổi học S03, học viên làm chủ các kỹ năng:

1. **Phân định** vai trò và trách nhiệm giữa Certificate Policy (CP) và Certification Practice Statement (CPS) theo RFC 3647.
2. **Thiết kế** quy trình Lễ sinh khóa (Key Ceremony) và quản trị khóa bằng thuật toán Shamir *M*-of-*N*.
3. **Phân tích** luồng thông điệp giao thức ACME (RFC 8555) và 3 cơ chế thử thách định danh (HTTP-01, DNS-01, TLS-ALPN-01).
4. **Vận hành** máy chủ Step-CA nội bộ hỗ trợ cấp chứng chỉ tự động cho hạ tầng DevOps/Kubernetes.

Nguyên Lý Vận Hành Hiện Đại. Chứng chỉ số ngắn hạn (90 ngày hoặc vài giờ) kết hợp tự động hóa 100% qua ACME là giải pháp hữu hiệu nhất để triệt tiêu lỗi vận hành và nâng cao tính an toàn của toàn hệ thống.


Chuẩn Đầu Ra Buổi Học S03 (Learning Objectives)

Sau buổi học S03, học viên làm chủ các kỹ năng:

1. **Phân định** vai trò và trách nhiệm giữa Certificate Policy (CP) và Certification Practice Statement (CPS) theo RFC 3647.
2. **Thiết kế** quy trình Lễ sinh khóa (Key Ceremony) và quản trị khóa bằng thuật toán Shamir ké-of-nl.
3. **Phân tích** luồng thông điệp giao thức ACME (RFC 8555) và 3 cơ chế thử thách định danh (HTTP-01, DNS-01, TLS-ALPN-01).
4. **Vận hành** máy chủ Step-CA nội bộ hỗ trợ cấp chứng chỉ tự động cho hạ tầng Dev/Ops/Kubernetes.

Nguyên Lý Vận Hành Hiện Đại. Chứng chỉ số ngắn hạn (90 ngày hoặc vài giờ) kết hợp tự động hóa 100% qua ACME là giải pháp hữu hiệu nhất để triệt tiêu rủi ro vận hành và nâng cao tính an toàn của toàn hệ thống.

S3-2 · Chuẩn Đầu Ra Buổi Học S03 (Learning Objectives)

[3 phút | 13h32–13h35] Nhấn mạnh xu hướng chứng chỉ ngắn hạn: Google đề xuất giảm thời hạn SSL xuống 45 ngày.

2. Khung Pháp lý & Kỹ thuật: RFC 3647 CP/CPS

So Sánh Certificate Policy (CP) & Practice Statement (CPS)

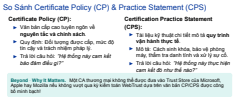
Certificate Policy (CP):

- Văn bản cấp cao tuyên ngôn về **nguyên tắc và chính sách**.
- Quy định: Đối tượng được cấp, mức độ tin cậy và trách nhiệm pháp lý.
- Trả lời câu hỏi: *"Hệ thống này cam kết bảo đảm điều gì?"*

Certification Practice Statement (CPS):

- Tài liệu kỹ thuật chi tiết mô tả **quy trình vận hành thực tế**.
- Mô tả: Cách sinh khóa, bảo vệ phòng máy, thẩm tra danh tính và xử lý sự cố.
- Trả lời câu hỏi: *"Hệ thống này thực hiện cam kết đó như thế nào?"*

Beyond · Why It Matters. Một CA thương mại không thể được đưa vào Trust Store của Microsoft, Apple hay Mozilla nếu không vượt qua kỳ kiểm toán WebTrust dựa trên văn bản CP/CPS được công bố minh bạch!



S3-3 · So Sánh Certificate Policy (CP) & Practice Statement (CPS)

[3 phút | 13h35–13h38] Phân biệt rõ CP và CPS. Đây là cơ sở pháp lý và kỹ thuật ràng buộc trách nhiệm của tổ chức CA.

Cấu Trúc 9 Phần Tiêu Chuẩn Của CP/CPS (RFC 3647)

1. **Giới thiệu chung (Introduction):** Phạm vi áp dụng, đối tượng tham gia và mã định danh OID của chính sách.
2. **Trách nhiệm công bố và kho lưu trữ (Publication & Repository):** Cam kết cập nhật CRL, URL chứng chỉ.
3. **Quy trình định danh và xác thực (Identification & Authentication):** Thẩm tra cá nhân, doanh nghiệp, tên miền.
4. **Yêu cầu nghiệp vụ vòng đời chứng chỉ (Certificate Life-Cycle Operations):** Nộp đơn, cấp phát, gia hạn, thu hồi.
5. **Kiểm soát an ninh cơ sở vật chất & nhân sự (Facility, Management Controls):** Phòng Faraday, camera, lý lịch quản trị.
6. **Kiểm soát an ninh kỹ thuật & mật mã (Technical Security Controls):** Chuẩn HSM, sinh số ngẫu nhiên TRNG.
7. **Hồ sơ cấu trúc chứng chỉ & CRL (Certificate, CRL Profiles):** Các trường ASN.1, thuật toán mã hóa.
8. **Đánh giá tuân thủ và kiểm toán độc lập (Compliance Audit):** Kiểm toán viên bên ngoài định kỳ hàng năm.
9. **Điều khoản pháp lý và kinh doanh (Other Business & Legal Matters):** Bồi thường thiệt hại, bảo mật thông tin.

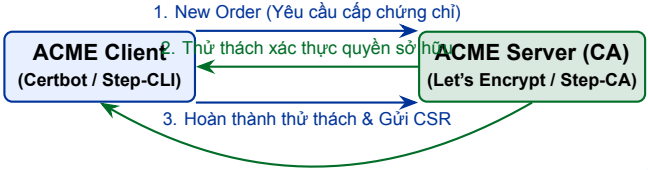


S3-4 · Cấu Trúc 9 Phần Tiêu Chuẩn Của CP/CPS (RFC 3647)

[3 phút | 13h38–13h41] Giới thiệu 9 phần của RFC 3647. Mọi sinh viên làm đề tài Đồ án Nhóm 4 (Enterprise ACME) cần tham chiếu khung này.

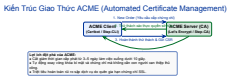
3. Tự Động Hóa Cấp Phát: Giao Thức ACME (RFC 8555)

Kiến Trúc Giao Thức ACME (Automated Certificate Management)



Lợi ích đột phá của ACME:

- Cắt giảm thời gian cấp phát từ 3–5 ngày làm việc xuống dưới 10 giây.
- Tự động xoay vòng khóa bí mật và chứng chỉ mà không cần con người can thiệp thủ công.
- Triệt tiêu hoàn toàn rủi ro sập dịch vụ do quên gia hạn chứng chỉ SSL.



S3-5 · Kiến Trúc Giao Thức ACME (Automated Certificate Management)

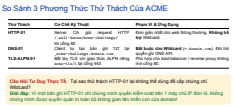
[3 phút | 13h41–13h44] Trình bày quy trình 4 bước của giao thức ACME theo chuẩn IETF RFC 8555.

So Sánh 3 Phương Thức Thử Thách Của ACME

Thử Thách	Cơ Chế Kỹ Thuật	Phạm Vi & Ứng Dụng
HTTP-01	Server CA gửi request HTTP `/.well-known/acme-challenge/` tới cổng 80	Đơn giản nhất cho web thông thường. **Không hỗ trợ** Wildcard.
DNS-01	Client tự tạo bản ghi `TXT` tại `_acme-challenge.domain.com`	**Bắt buộc cho Wildcard** (`*.domain.com`). Đòi hỏi quyền ghi DNS API.
TLS-ALPN-01	Bắt tay TLS với giao thức ALPN riêng `acme-tls/1` tại cổng 443	Phù hợp cho load balancer / reverse proxy không mở cổng 80.

Câu Hỏi Tư Duy Thực Tế. Tại sao thử thách HTTP-01 lại không thể dùng để cấp chứng chỉ Wildcard?

Giải đáp: Vì một bản ghi HTTP-01 chỉ chứng minh quyền kiểm soát trên 1 máy chủ IP đơn lẻ, không chứng minh được quyền quản trị toàn bộ không gian tên miền con của domain!


So Sánh 3 Phương Thức Thử Thách Của ACME

Thử Thách	Cơ Chế Kỹ Thuật	Phạm Vi & Ứng Dụng
HTTP-01	Server CA gửi request HTTP /.well-known/acme-challenge/ tới cổng 80	Đơn giản nhất cho web thông thường. Không hỗ trợ Wildcard.
DNS-01	Client tự tạo bản ghi TXT tại _acme-challenge.domain	Bắt buộc cho Wildcard (*.domain.com). Hỗ trợ mọi cổng.
TLS-ALPN-01	Bắt tay TLS với giao thức ALPN cổng acme-tls/1 tại cổng 443	Phù hợp cho load balancer / reverse proxy không mở cổng 80.

Câu Hỏi Tư Duy Thực Tế. Tại sao thử thách HTTP-01 lại không thể dùng để cấp chứng chỉ Wildcard?

Giải đáp: Vì một bản ghi HTTP-01 chỉ chứng minh quyền kiểm soát trên 1 máy chủ IP đơn lẻ, không chứng minh được quyền quản trị toàn bộ không gian tên miền con của domain!

S3-6 · So Sánh 3 Phương Thức Thử Thách Của ACME

[3 phút | 13h44–13h47] So sánh 3 challenge của ACME. Lưu ý sinh viên: Khi xin chứng chỉ Wildcard, bắt buộc phải dùng DNS-01.

4. Thực hành Triển khai Step-CA Nội bộ

Triển Khai Máy Chủ ACME Nội Bộ Bằng Step-CA

```
# 1. Khoi dong Step-CA server ho tro ACME protocol
docker run -d --name step-ca -p 9000:9000 \
  -e "DOCKER_STEPCA_INIT_NAME=KMA Enterprise PKI" \
  -e "DOCKER_STEPCA_INIT_DNS_NAMES=localhost,step-ca.kma.local" \
  smallstep/step-ca

# 2. Cau hinh client lay chung chi tu dong bang Certbot
certbot certonly --standalone \
  --server https://step-ca.kma.local:9000/acme/acme/directory \
  -d api.kma.internal
```

Ứng Dụng Trong Doanh Nghiệp. Step-CA cho phép mọi tổ chức xây dựng một ”Let’s Encrypt nội bộ” hoàn toàn miễn phí, độc lập, bảo mật cho hệ thống microservices và mạng LAN riêng tư.



S3-7 · Triển Khai Máy Chủ ACME Nội Bộ Bằng Step-CA

[3 phút | 13h47–13h50] Hướng dẫn thực hành Lab 2: Khởi động Step-CA bằng Docker và dùng Certbot cấp phát chứng chỉ tự động.

Bài Tập Tự Kiểm Tra Buổi S03

Câu Hỏi Thẩm Định Năng Lực.

1. **Câu 1:** Một doanh nghiệp có 500 microservices chạy trong Kubernetes. Vì sao họ nên dùng ACME thay vì sinh chứng chỉ tĩnh bằng OpenSSL?
   Giải đáp: Với 500 dịch vụ, việc tạo khóa và gia hạn thủ công sẽ gây quá tải vận hành và chắc chắn xảy ra sự cố quên gia hạn làm sập hệ thống. ACME tự động hóa 100% việc cấp và xoay vòng chứng chỉ.
2. **Câu 2:** Trong lễ sinh khóa Root CA, nếu 1 trong số M người nắm giữ thẻ Shamir bị mất thẻ, hệ thống có mở khóa được không?
   Giải đáp: Có, miễn là còn đủ M người trong số N người ($M \leq N$). Đó chính là ưu việt của thuật toán chia sẻ bí mật Shamir so với khóa đơn lẻ.


Bài Tập Tự Kiểm Tra Buổi S03

Câu Hỏi Thẩm Định Năng Lực

1. **Câu 1:** Một doanh nghiệp có 500 microservices chạy trong Kubernetes. Vì sao họ nên dùng ACME thay vì sinh chứng chỉ tĩnh bằng OpenSSL?
   Giải đáp: Với 500 dịch vụ, việc tạo khóa và gia hạn thủ công sẽ gây quá tải vận hành và chắc chắn dẫn đến sự cố. Ngược lại, ACME tự động hóa 100% việc cấp và xoay vòng chứng chỉ.
2. **Câu 2:** Trong lễ sinh khóa Root CA, nếu 1 trong số M người nắm giữ thẻ Shamir bị mất thì, hệ thống có mở khóa được không?
   Giải đáp: Có, miễn là còn đủ M người trong số N người (M ≤ N). Đó chính là ưu việt của thuật toán chia sẻ bí mật Shamir so với khóa đơn lẻ.

S3-8 · Bài Tập Tự Kiểm Tra Buổi S03

[2 phút | 13h50–13h52] Tổng kết buổi học S03 và giao bài tập Lab 2.